DOKUMEN REFERENSI KNOWLEDGE BASE - MODUL 01

KNOWLEDGE_DOCS: KEPATUHAN HUKUM, REGULASI PDP & STANDAR KONTROL BISNIS

Panduan Regulasi Kebocoran Data dan Kewajiban Hukum Pelindungan Data Pribadi v1.0

CATATAN SISTEM

Dokumen ini mengatur aspek kepatuhan (*compliance*) hukum dan kewajiban bisnis di Indonesia terkait perlindungan data pribadi dan penanganan insiden kejahatan siber.

MODUL 1: Kewajiban Pengendali Data Menurut UU PDP (UU No. 27/2022)

Setiap entitas bisnis yang mengumpulkan atau mengelola data pribadi konsumen/karyawan dikategorikan sebagai Pengendali Data Pribadi dan wajib mematuhi ketentuan berikut:

- **Notifikasi Kebocoran Data (Pemberitahuan Tertulis):** Apabila terjadi kegagalan perlindungan data pribadi, Pengendali Data wajib menyampaikan pemberitahuan tertulis paling lambat **3 x 24 jam** kepada Lembaga Pelindung Data Pribadi dan pemilik data.
- **Penunjukan Data Protection Officer (DPO):** Bisnis yang melakukan pemrosesan data pribadi dalam skala besar atau aktivitas pemrosesan berisiko tinggi wajib menunjuk pejabat/petugas pelindung data pribadi.
- **Penyusunan Data Protection Impact Assessment (DPIA):** Analisis dampak perlindungan data wajib dilakukan sebelum menjalankan teknologi baru yang berpotensi memproses data sensitif.

MODUL 2: Kerangka Kerja & Sertifikasi Keamanan Standar Industri

Standar Keamanan	Fokus Utama	Relevansi Bisnis
ISO/IEC 27001	Sistem Manajemen Keamanan Informasi (SMKI) menyeluruh berbasis risiko.	Standar utama kepercayaan pelanggan dan syarat kemitraan enterprise.
NIST Cybersecurity Framework	5 Pilar: Identify, Protect, Detect, Respond, Recover.	Panduan praktis perancangan mitigasi serangan teknis.
PCI-DSS	Keamanan pemrosesan dan transaksi kartu kredit/pembayaran digital.	Wajib bagi bisnis e-commerce dan financial technology.

MODUL 3: Sanksi dan Risiko Kebocoran Data

Kegagalan dalam menjaga kerahasiaan data pribadi dapat berakibat pada sanksi administratif hingga pidana:

- Sanksi administratif berupa peringatan tertulis, penghentian sementara kegiatan pemrosesan data, hingga denda administratif maksimal 2% dari total pendapatan tahunan.
- Sanksi pidana terhadap pihak yang secara melawan hukum memperoleh atau mengungkapkan Data Pribadi yang bukan miliknya.